

dùng regex tìm đúng định dạng key của từng nhà cung cấp (AWS, OpenAI, Google, Stripe...). Key lộ trên repo public bị phát hiện và **bị dùng trong vòng vài phút** — không phải vài ngày. Kịch bản quen thuộc: key AWS lộ buổi tối, sáng hôm sau tài khoản có hoá đơn vài nghìn đô tiền máy đào coin.

Repo private thì đỡ hơn, nhưng đừng coi là an toàn: key nằm trong lịch sử là quả mìn hẹn giờ — chờ ngày repo đổi public, thêm collaborator, hay một bản clone nằm lại trên máy ai đó.

Mật khẩu database cũng cùng số phận: chuỗi kết nối `mysql://user:password@host` viết thẳng trong code là mật khẩu nằm trong Git.

2. Phòng: .env và biến môi trường

Cách phòng chuẩn, dùng ở mọi ngôn ngữ: **secret ra khỏi code, vào file .env** — một file text nhỏ nằm ở gốc dự án, mỗi dòng một biến:

```
OPENWEATHER_API_KEY=sk-live-9f8e7d6c5b4a3f2e1d0c
DB_PASSWORD=s3cret-pa55
```

Code **không chứa giá trị nữa** — nó đọc qua **biến môi trường**, kiểu như:

```
import os

api_key = os.environ["OPENWEATHER_API_KEY"]
weather = fetch_weather("Hanoi", api_key)
```

Code giờ nói *"tôi cần một key tên là OPENWEATHER_API_KEY"* chứ không nói key là gì. Giá trị thật nằm trong **.env trên máy bạn** — mỗi người trong nhóm có bản **.env** riêng, chứa key của mình. (Thư viện như **python-dotenv** giúp nạp **.env** vào biến môi trường lúc chạy — biết tên để tra.)

Tách xong, code push thoải mái — thứ tuyệt đối không được push là **.env**. Đó là việc của mục sau.

3. .gitignore ngay khi tạo repo

Dòng **.env** phải vào **.gitignore** ngay lúc tạo repo, trước cả commit đầu tiên:

```
echo ".env" >> .gitignore
git add .gitignore
git commit -m "ignore .env"
```

Vì sao phải "ngay"? Hai lý do:

- **.gitignore** chỉ chặn file **chưa được track**. Lỡ commit **.env** một lần rồi mới thêm vào